A05 — Arquitetura de Segurança, Autenticação e Autorização

1. Visão Geral da Autenticação

O ecossistema do **SmartLog** utiliza o **Firebase Authentication** como camada primária de identidade e segurança.

- **Fluxo de Credenciais:** Os usuários (Administradores, Motoristas e Clientes) autenticam-se por meio de e-mail e senha.
- **Sessão e Tokens:** Após o login bem-sucedido, o Firebase gera um token de sessão seguro e exclusivo (`UID`), permitindo que o aplicativo mantenha a persistência do usuário sem expor dados sensíveis.

2. Regras de Acesso e Perfis (Role-Based Access Control - RBAC)

Para atender aos requisitos de controle de acesso, o sistema divide os usuários em três perfis independentes armazenados no Cloud Firestore:

- **ADMIN (Administrador da Empresa):**
  - *Permissões:* Acesso total ao painel administrativo (`dashboard_admin.dart`), permitindo a gestão de entregas por zonas geográficas de São Paulo, visualização de rotas, cadastro de novos motoristas e monitoramento dos clientes corporativos.
  - *Escopo:* Restrito estritamente à sua própria organização por meio do isolamento de dados via `empresaId`.
- **MOTORISTA:**
  - *Permissões:* Acesso à visão operacional para consultar rotas designadas à sua região, atualizar o status das entregas (*Pendente*, *Em Rota*, *Entregue*) e registrar o recebimento de mercadorias via aplicativo.
  - *Escopo:* Limitado apenas às entregas e rotas vinculadas ao seu respectivo perfil e empresa.
- **CLIENTE:**
  - *Permissões:* Acompanhamento em tempo real do status e rastreio de suas encomendas cadastradas no sistema.
  - *Escopo:* Acesso restrito exclusivamente ao histórico de seus próprios pedidos.

3. Isolamento de Dados (Arquitetura Multi-Tenant)

O sistema garante a privacidade e a segurança dos dados corporativos (em conformidade com as diretrizes da parceria com a Leroy Merlin) através do conceito de **Multi-Tenant com `empresaId`**:

- No momento em que o Administrador cadastra um novo motorista pelo painel, o sistema injeta automaticamente o identificador da empresa (`empresaId`) no documento do Firestore do novo usuário.
- Desta forma, nenhum usuário consegue cruzar barreiras de dados entre empresas diferentes, garantindo blindagem contra acessos indevidos.

4. Tratamento de Acesso Inválido e Não Autorizado

Para assegurar a robustez da aplicação frente a falhas de segurança ou tentativas de navegação indevida:

- **Sessão Expirada / Token Inválido:** Caso o token do usuário deixe de existir ou a sessão caia, a aplicação intercepta o estado, exibe um aviso visual amigável via `SnackBar` e redireciona imediatamente o usuário de volta para a tela de login (`/login`).
- **Tentativa de Acesso a Rotas Restritas:** Se um perfil de menor privilégio tentar acessar telas ou ações exclusivas de administrador, o roteamento do aplicativo bloqueia a navegação e impede a execução de métodos sensíveis no `DashboardController`.
-